AWS COMMUNITY DAY PARAGUAY 2026

authentik en AWS

Tu propio IdP con CloudFormation, IAM Identity Center y un ALB que hace el login por vos

Marcelo Elizeche Landó

co-maintainer de authentik

Asunción · 17/10/2026

QUIÉN SOY

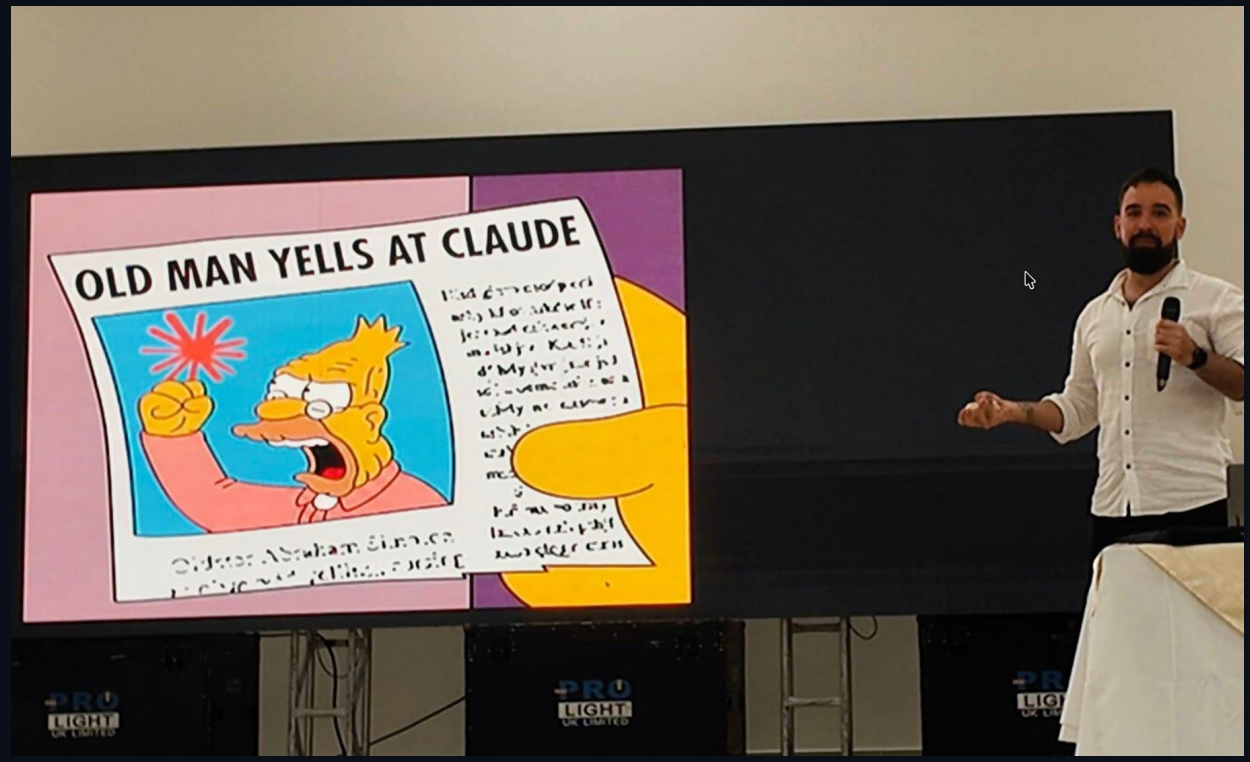
Marcelo Elizeche Landó

authentik

Desarrollador de software y co-maintainer: features, releases y documentación

Comunidad

Fundador y organizador de Python Paraguay, PSF Fellow, miembro de la Django Software Foundation



EL PROBLEMA

Cada sistema tiene sus propios usuarios

Usuarios IAM

Uno por persona y por cuenta, con su contraseña y sus access keys

Apps internas

Un login propio, una contraseña compartida o nada

Bajas

Alguien se va y hay que acordarse de sacarlo de cada lugar

CONCEPTOS

Qué es un proveedor de identidad (IdP)



Guarda

Usuarios, grupos y sus atributos, en un solo lugar



Autentica

Comprueba quién sos: contraseña, MFA, passkey



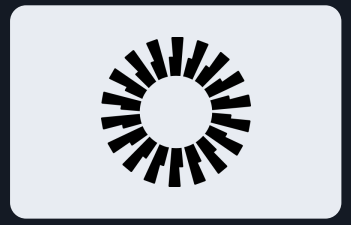
Afirma

Les dice a las apps quién sos, con un documento firmado

Las apps no ven tu contraseña: confían en lo que firma el IdP.

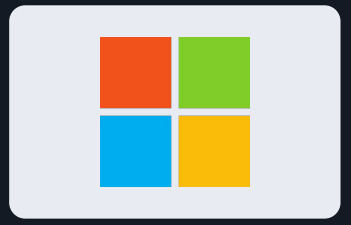
CONCEPTOS

Probablemente ya usaste un IdP



Okta

SaaS



Microsoft Entra ID

SaaS



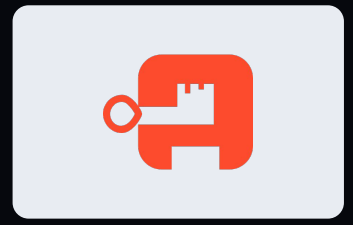
Google Workspace

SaaS



Keycloak

Open source · self-hosted



authentik

Open source · self-hosted

CONCEPTOS

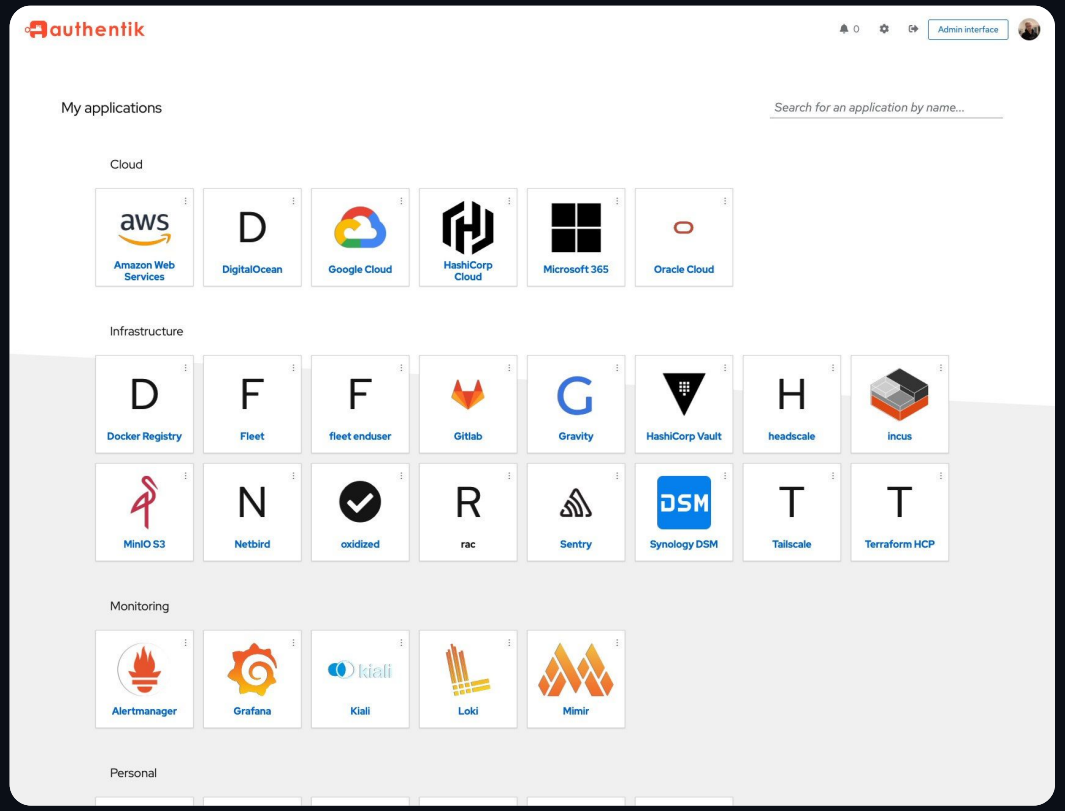
SSO: un login, todas las apps



- Una sola credencial que proteger
- MFA en un lugar, para todo
- Una baja corta todos los accesos
- Un registro de quién entró a qué

CONCEPTOS · ASÍ SE VE

Un portal con todas tus apps



- Cada usuario ve **solo las apps** a las que tiene acceso
- Un click y entrás, **sin otro login**
- Agrupadas por categoría
- Nube, infra y monitoreo, **todo detrás del mismo IdP**

QUÉ ES AUTHENTIK

Un proveedor de identidad open source que corrés vos

Habla los protocolos que ya entienden tus aplicaciones:

SAML SCIM OAuth2 / OIDC LDAP RADIUS Proxy

Hoy usamos los tres primeros.

QUIÉN LO USA

Del homelab a la empresa, la misma herramienta

Homelabs y self-hosting

Uno de los IdP favoritos de la comunidad para poner un login único delante de todo lo que corre en casa

Algunas empresas y organizaciones

- Cloudflare
- Anduril
- CoreWeave
- Der Spiegel
- T-Systems
- Cruz Roja Austríaca

fuente: goauthentik.io

QUÉ ES AUTHENTIK

Las piezas con las que se arma todo

Flows y stages

Cada login, registro o recuperación es una secuencia de pasos que armás vos

Apps y providers

La app que ve el usuario y el protocolo con el que habla: SAML, OIDC, SCIM

Políticas

Quién puede entrar a qué y cuándo, incluso en Python

Sources

Traer usuarios de afuera: Google, GitHub, LDAP, otro IdP

Outposts

Proxy, LDAP y RADIUS que corren cerca de las apps

Blueprints

La configuración como archivos YAML versionables


PCMCIA – People can't memorize computer industries acronyms.
Andy Grove
quotefancy

GLOSARIO

Las siglas de hoy

IdP
Guarda usuarios, los autentica y les avisa a las apps

SSO
Un login y entrás a todas las apps que confían en el IdP

SAML
Login federado en XML. Lo usa la consola de AWS

OIDC
Login sobre OAuth2 con tokens JWT. Lo usa el ALB

SCIM
API para crear, cambiar y borrar usuarios en otra app

JWT
Token firmado en tres partes: header, payload y firma

Passkey
WebAuthn: par de claves; la privada queda en tu dispositivo

IAM Identity Center
El SSO de AWS: acceso por grupo y permission set

CloudFormation
Infraestructura como código: un template, un stack

ALB
Balanceador HTTPS que también puede hacer el login

ACM
AWS Certificate Manager: el certificado TLS del ALB

ECS Fargate · RDS
Contenedores sin servidores y PostgreSQL administrado



El post

blog.melizeche.com

QUÉ VAMOS A ARMAR

Una puerta de entrada para todo



Demo 1

authentik en ECS, RDS y ALB

Demo 2

consola de AWS por SAML y SCIM

Demo 3

una app detrás del ALB con OIDC

Demo 4

todo lo anterior, con passkeys

ANTES DE ARRANCAR

Tres formas de instalarlo

Docker Compose

Lo más simple y barato: ~US$ 30/mes en un EC2 t4g.medium (o 0$ en tu home lab)

Kubernetes

Helm chart, si ya tenés un cluster k8s

CloudFormation

Servicios administrados de AWS. Pensado para organizaciones que ya viven en AWS

DEMO 1 · CLOUDFORMATION

Qué crea el template oficial

VPC
subredes públicas y privadas

RDS
PostgreSQL

ECS Fargate
server y worker

ALB
HTTPS con tu certificado

EFS
dos volúmenes

Secrets Manager
claves y contraseñas

Sin Redis: authentik no lo usa desde la versión 2025.10.

DEMO 1 · CLOUDFORMATION

Una variante mínima para la demo

	Oficial	Demo
Base de datos	db.m5.large, Multi-AZ	db.t4g.small, Single-AZ
Tareas server / worker	2 / 2	1 / 1
NAT Gateway	1	ninguno
Al borrar el stack	deja snapshot, EFS y logs	se borra todo
Costo aproximado	US$ 0,55/h · ~US$ 400/mes	US$ 0,13/h · ~US$ 97/mes

Precios on-demand en us-east-1, sin tráfico ni impuestos.

DEMO 1 · CLOUDFORMATION

Primero, el certificado de ACM

Los dos dominios validados por DNS y el certificado sigue en *Pending validation*. Termina en **FAILED** con motivo **CAA_ERROR**: el dominio tenía registros CAA que no autorizaban a Amazon.

El arreglo, en tu DNS:

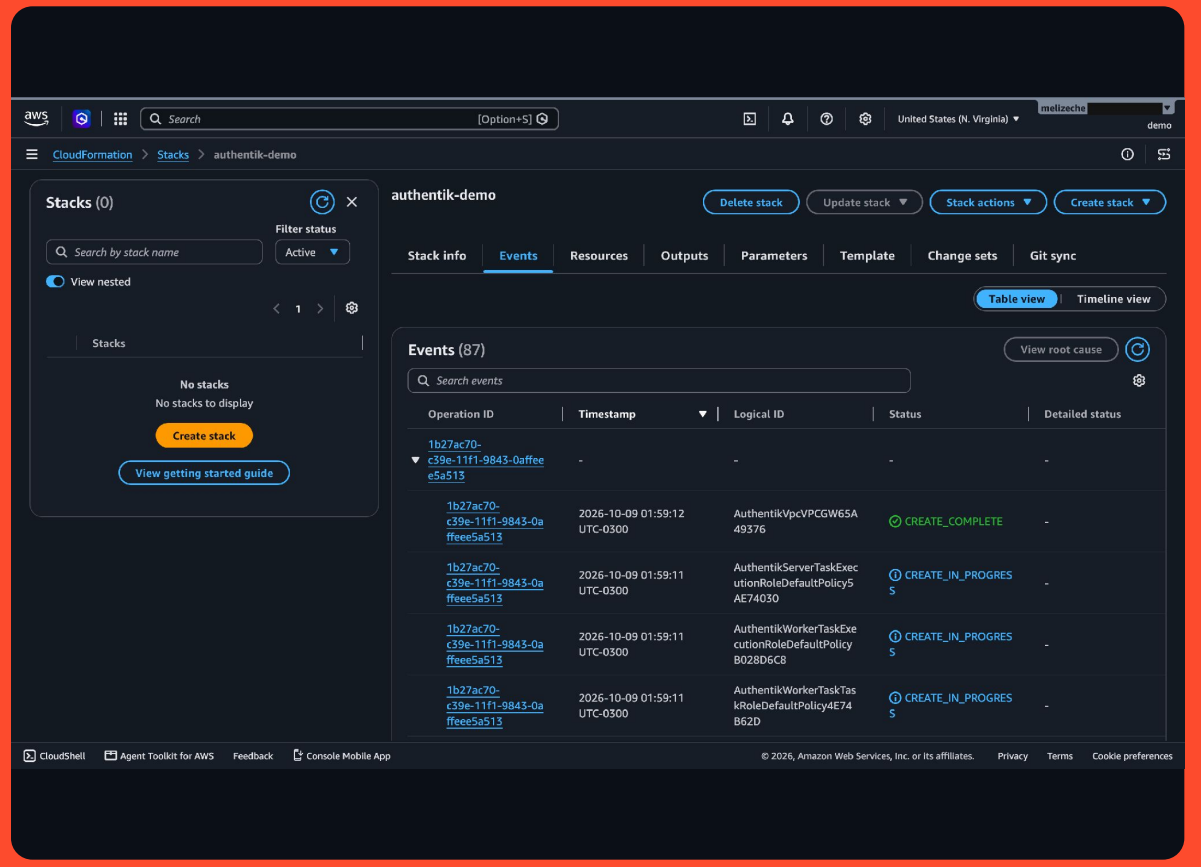
```
CAA 0 issue "amazon.com"
```

y pedir un certificado nuevo

DEMO EN VIVO

Desplegar authentik

1. Subir el template
2. Parámetros: certificado y versión
3. Seguir los eventos
4. CNAME y setup inicial



DEMO 1 · LO QUE ME TRABÓ

Tres errores del primer despliegue

`gp3 con 10 GB`	RDS exige 20 GB para gp3 en PostgreSQL. Volví a gp2.
`no pg_hba.conf entry ... no encryption`	RDS con PostgreSQL 15+ exige TLS. Faltaba **SSLMODE=require**; corregido en 2026.8.4 (PR #26807).
`CREATE_IN_PROGRESS por horas`	Sin circuit breaker, CloudFormation espera para siempre. Bajá las tareas a 0.

DEMO 2 · IAM IDENTITY CENTER

Dos protocolos, dos trabajos distintos

SAML

El login

Cuando alguien entra, authentik le confirma a AWS quién es

SCIM

El directorio

authentik crea, actualiza y borra usuarios y grupos en AWS antes del login

DEMO 2 · SAML

El login en cuatro pasos

1

AWS

Bajar la metadata del service provider

2

authentik

Crear la app con SAML desde esa metadata

3

AWS

Subir la metadata de authentik como IdP

4

AWS

Asignar grupo y permission set

El detalle que importa: **NameID = email**. AWS lo cruza con el username de Identity Center.

DEMO 2 · SCIM

El provider SCIM, configurado para AWS

Property mapping "zz AWS SCIM User"

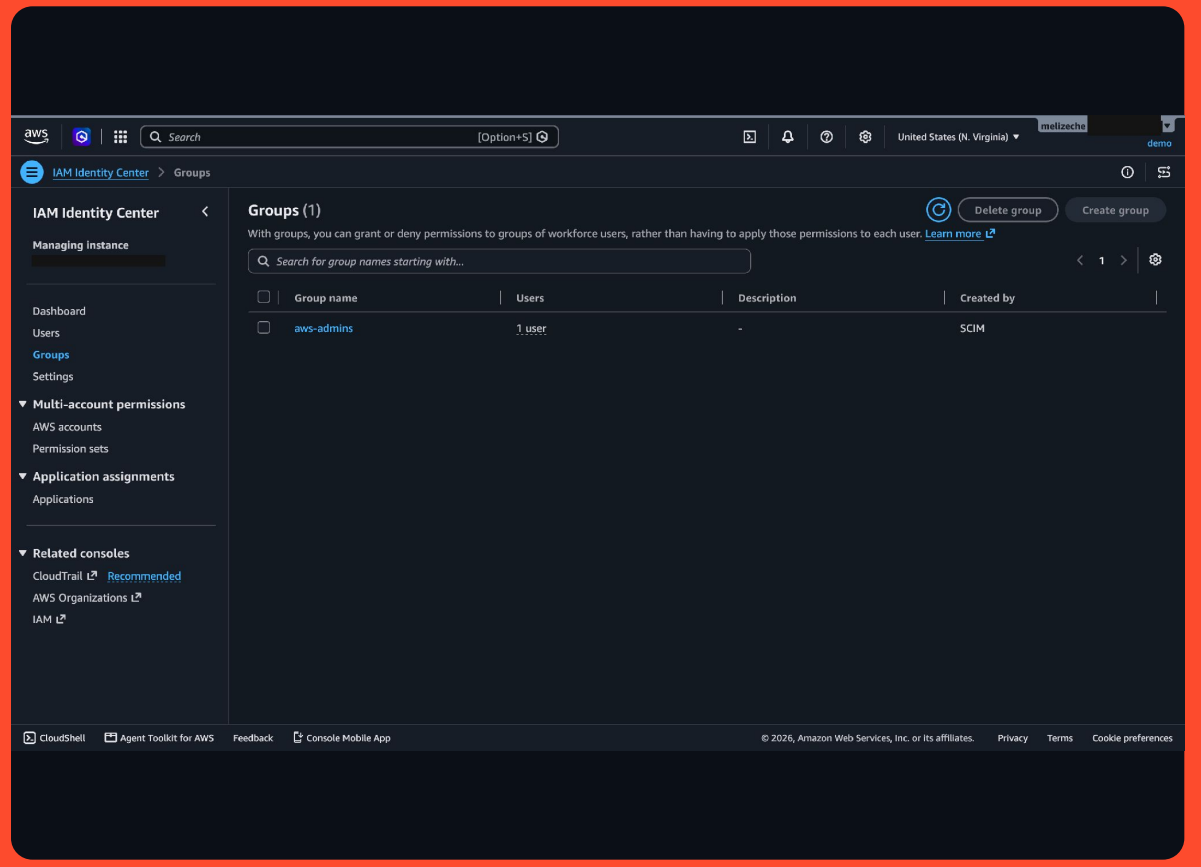
```
return {
  "photos": None,
  "userName":
request.user.email,
}
```

- **Compatibility Mode** en AWS
- **Group filter** con un solo grupo, sin service accounts
- El provider como **backchannel** de la app SAML
- Probar primero con **dry run**

DEMO EN VIVO

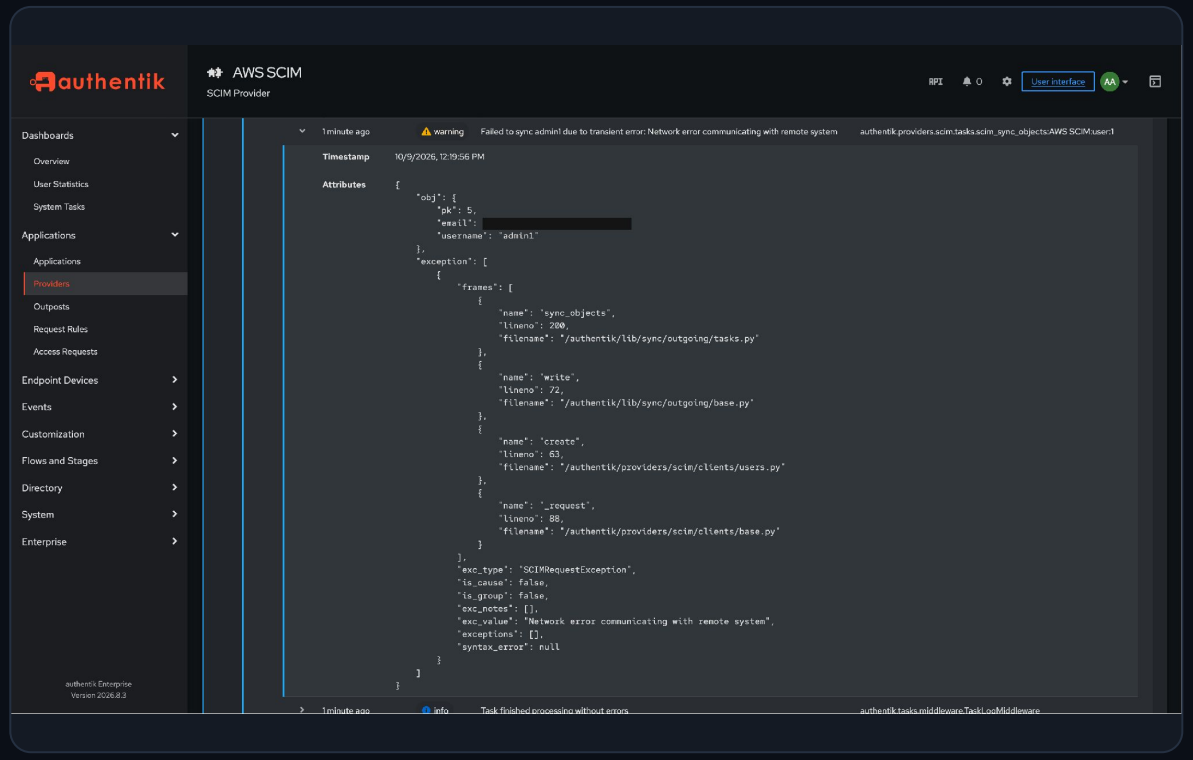
Entrar a la consola de AWS

1. Sync SCIM: el usuario aparece en AWS
2. Login desde authentik
3. Consola con ReadOnlyAccess
4. Sacar al usuario del grupo



DEMO 2 · LO QUE ME TRABÓ

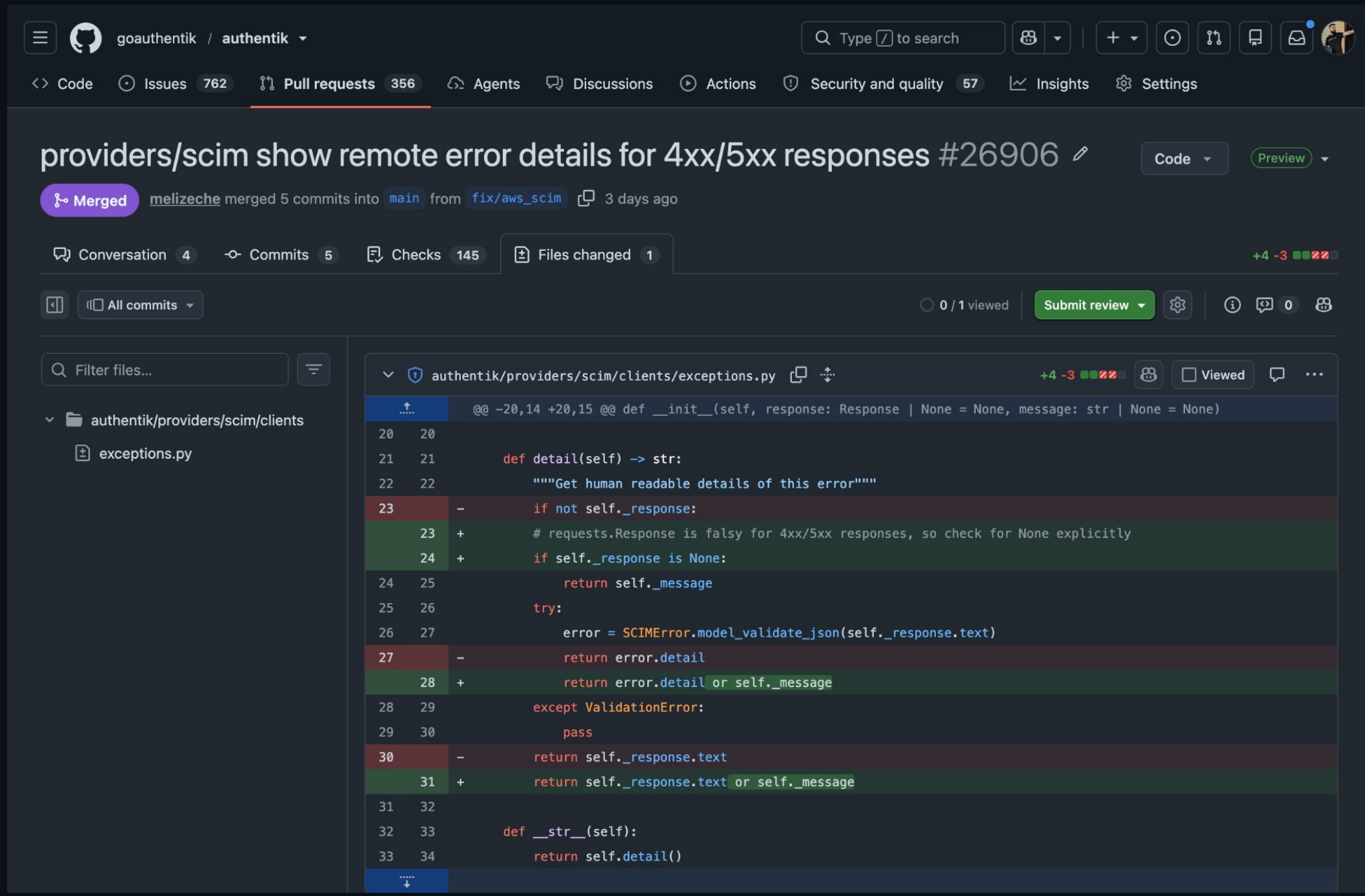
Un "Network error" que no era de red



AWS respondió **400**: el usuario no tenía nombre y Identity Center lo exige.

El detalle real está en los logs del worker: **Failed to send SCIM request**.

Y en SAML: copiá la ACS URL exacta que muestra AWS.


goauthentik / authentik
Type / to search
Code
Issues 762
Pull requests 356
Agents
Discussions
Actions
Security and quality 57
Insights
Settings
providers/scim show remote error details for 4xx/5xx responses #26906
Code
Preview
Merged
melizeche merged 5 commits into main from fix/aws_scim 3 days ago
Conversation 4
Commits 5
Checks 145
Files changed 1
+4 -3
All commits
0 / 1 viewed
Submit review
0
Filter files...
authentik/providers/scim/clients
exceptions.py
authentik/providers/scim/clients/exceptions.py
+4 -3
Viewed
@@ -20,14 +20,15 @@ def __init__(self, response: Response | None = None, message: str | None = None)
def detail(self) -> str:
"""Get human readable details of this error"""
- if not self._response:
+ # requests.Response is falsy for 4xx/5xx responses, so check for None explicitly
+ if self._response is None:
return self._message
try:
error = SCIMError.model_validate_json(self._response.text)
- return error.detail
+ return error.detail or self._message
except ValidationError:
pass
- return self._response.text
+ return self._response.text or self._message
def __str__(self):
return self.detail()

DEMO 2 · LO QUE ME TRABÓ

Fixed ✅ (PR #26906)

Current execution logs

	Time	Level	Event	Logger
›	2 hours ago	info	Task is being processed	authentik.tasks.middleware.TaskLogMiddleware
›	2 hours ago	info	Syncing page 1 or Users	authentik.providers.scim.tasks.scim_sync_objects:AWS SCIM:user:1
›	2 hours ago	info	Task has been queued	authentik.tasks.middleware.TaskLogMiddleware
›	2 hours ago	warning	Failed to sync aaa due to transient error: name.givenName: Empty string value is not allowed for this attribute	authentik.providers.scim.tasks.scim_sync_objects:AWS SCIM:user:1
›	2 hours ago	info	Task finished processing without errors	authentik.tasks.middleware.TaskLogMiddleware

Last refreshed 46 seconds ago

DEMO 3 · ALB + OIDC

El ALB hace el login antes que la app

1. El navegador pide la app
2. El ALB lo manda a authentik
3. Login y vuelta con un código
4. El ALB canjea el código por tokens
5. La app recibe headers con el usuario

La app no implementa ningún login. Ideal para herramientas internas con una contraseña compartida.

DEMO 3 · ALB + OIDC

La regla del listener

```
- Type: authenticate-oidc
  Order: 1
  AuthenticateOidcConfig:
    Issuer: https://auth.../application/o/<slug>/
    AuthorizationEndpoint: .../application/o/authorize/
    TokenEndpoint: .../application/o/token/
    UserInfoEndpoint: .../application/o/userinfo/
    ClientId / ClientSecret
    Scope: openid email profile
- Type: forward
  Order: 2
```

En authentik

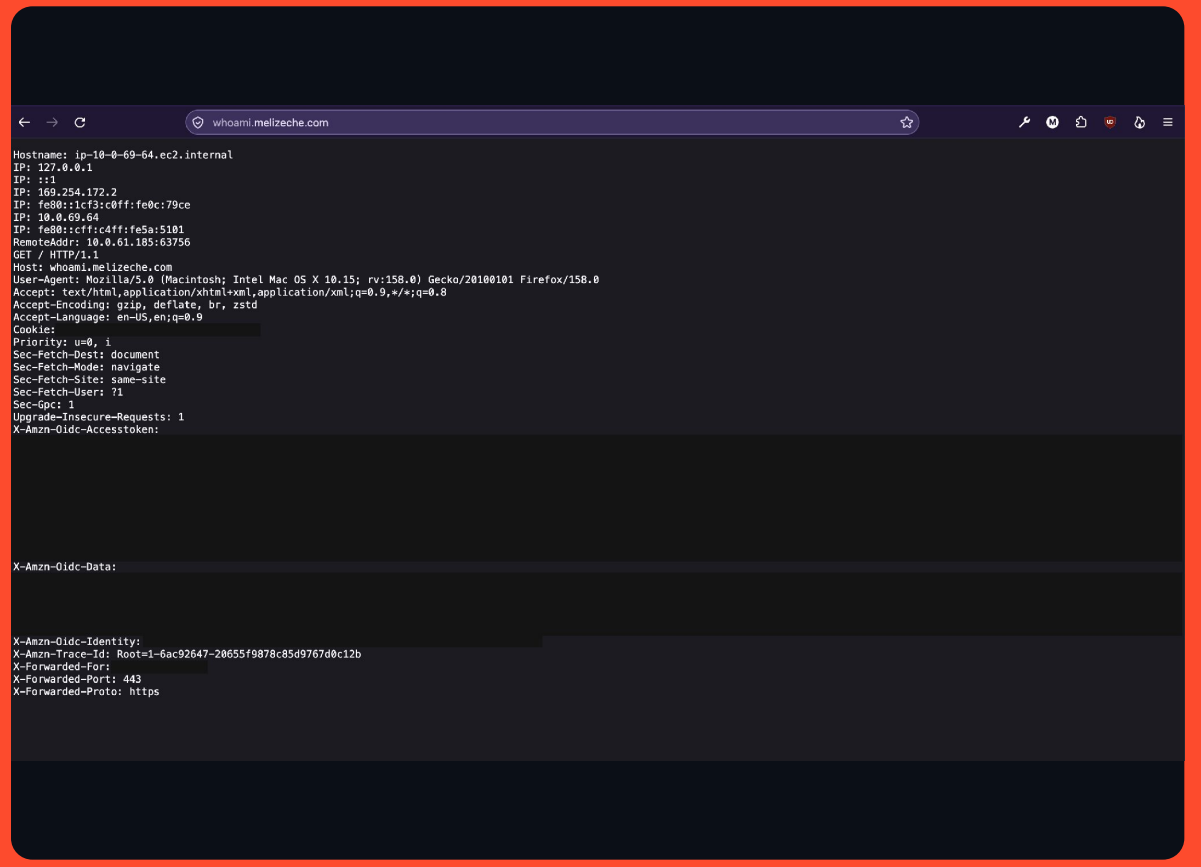
- Provider OAuth2/OpenID, **Confidential**
- Redirect URI **Strict**: /oauth2/idpresponse
- Sin **claims en el id_token**
- Bindings: quién puede entrar

Guía oficial: AWS ALB, en integrations.goauthentik.io

DEMO EN VIVO

Una app sin login, protegida

1. Abrir la app en privado
2. Login en authentik
3. whoami: usuario y grupos
4. Los headers del ALB



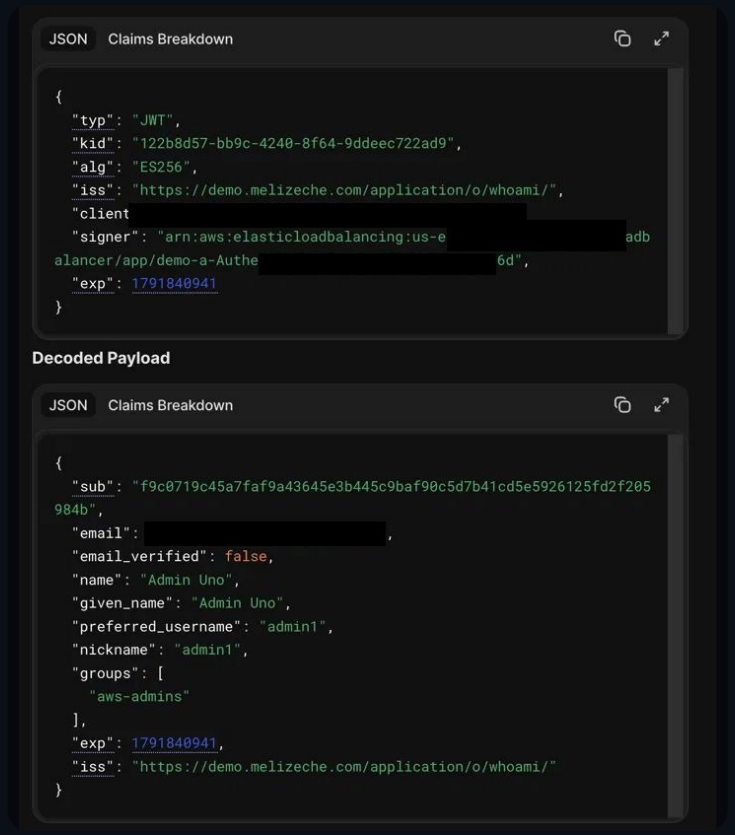
DEMO 3 · LO QUE ME TRABÓ

Los errores, en orden

Síntoma	Causa	Arreglo
Target.Timeout, circuit breaker	El ALB no tiene salida hacia la app	Egress del ALB al puerto 80
Redirect URI Error	No coincide con el que manda el ALB	/oauth2/idpresponse, Strict
500 en /oauth2/idpresponse	El ALB no llega al token endpoint	Egress del ALB al 443
500 con usuarios de muchos grupos	Claims y access token pasan de 11 KB	Scope profile propio, con menos grupos
561 Authentication Error	authentik rechazó el canje: Invalid client secret	Corregir el secret en la regla

DEMO 3 · SEGURIDAD

No le creas al header sin verificarlo



- Lo firma el **ALB con ES256**, no authentik
- Verificalo con la **clave pública del ALB**: el header dice cuál bajar
- Chequeá **signer** (tu ALB), **iss**, **client** y **exp**
- Identity y Accesstoken **no van firmados**
- La firma cubre el padding **=**: no lo saques antes de verificar
- La app acepta tráfico **solo desde el ALB**

DEMO 4 · PASSKEYS

Una passkey no tiene secreto que robar

Contraseña

El mismo secreto en los dos lados

- Se puede filtrar del servidor
- Se puede tipear en un sitio falso
- Se reutiliza

Passkey (WebAuthn)

Un par de claves

- La privada no sale de tu dispositivo
- El servidor guarda solo la pública
- Atada al dominio: no sirve en un sitio falso

DEMO 4 · PASSKEYS

Login sin contraseña en authentik

1

Enrolar

El usuario registra su passkey con el stage *WebAuthn / FIDO2 / Passkeys*

2

Validar

Un stage *Authenticator Validation* que acepte WebAuthn

3

Ofrecer

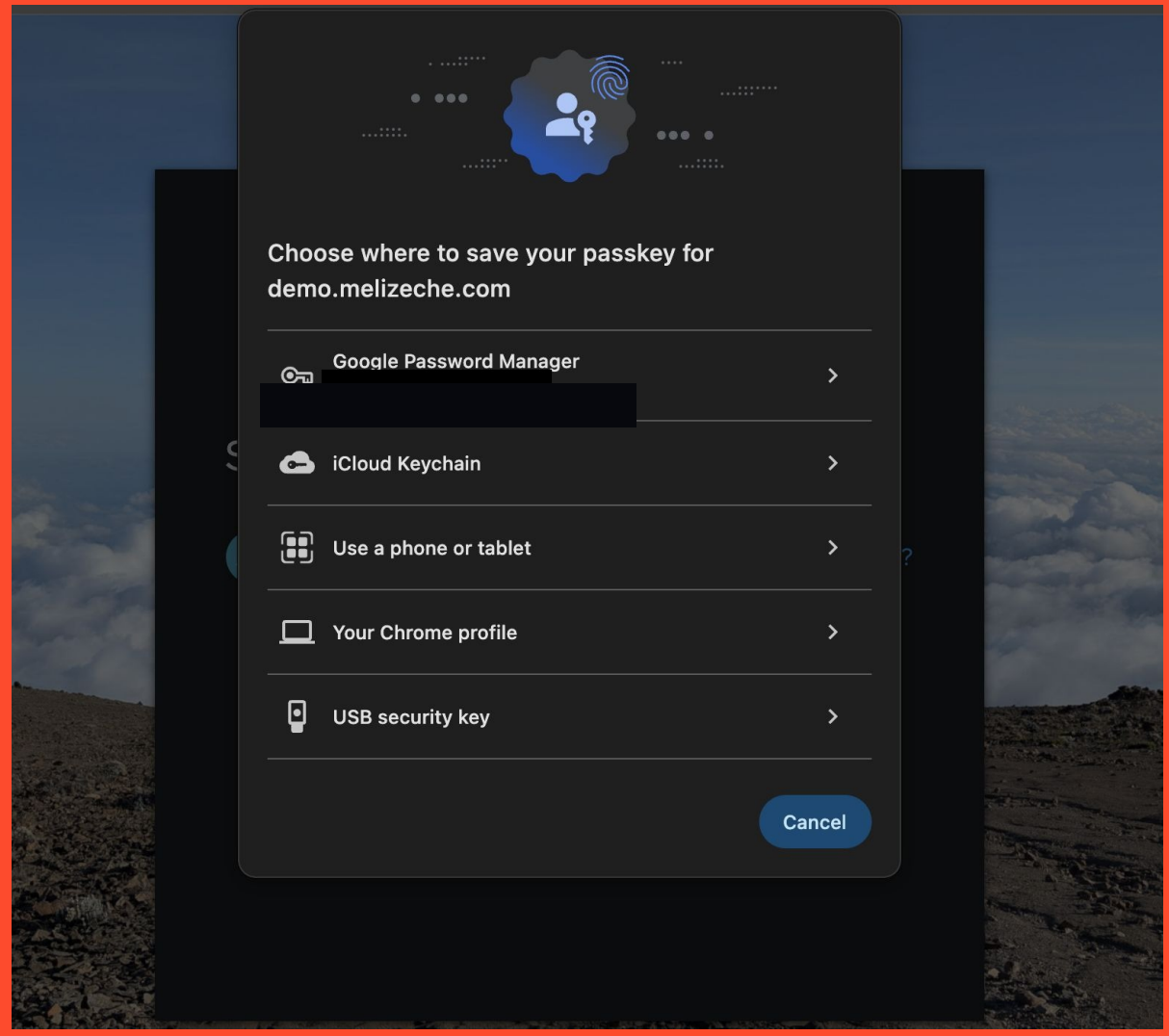
En el *Identification stage*, ese stage como *WebAuthn Authenticator Validation Stage*

Requisitos: HTTPS, passkey **discoverable** (resident key), mismo hostname donde se creó. Autofill desde authentik 2025.12.

DEMO EN VIVO

Entrar sin contraseña

1. Registrar una passkey
2. Cerrar sesión
3. Login con autofill, sin contraseña
4. Consola de AWS y whoami, sin contraseña



DE DEMO A PRODUCCIÓN

Lo que hay que volver a poner

	Demo	Mínimo para producción
Base de datos	Single-AZ	Multi-AZ
Backups de RDS	no	7 días, point-in-time
Cifrado de RDS	no	StorageEncrypted
TLS a Postgres	require	verify-full con el CA de RDS
Red de las tareas	pública, sin NAT	privada, con NAT
Circuit breaker de ECS	no	sí, con rollback
Backups EFS, deletion protection	no	sí
Costo aproximado	~US$ 97/mes	~US$ 172/mes

LIMPIEZA

Antes de borrar, en este orden

1. Volver el identity source de Identity Center a su directorio
2. Borrar el stack de la app
3. Borrar el stack de authentik

Gracias

Todo lo de hoy, paso a paso y con el código.

¿Preguntas?

El post

`blog.melizeche.com`

El repo

`melizeche/authentik_aws_demo`

Marcelo Elizeche Landó (@melizeche)